TECHNICAL CONSTRUCTION FILE (TCF): SE-500 GATEWAY

Document Status: FORMAL AUDIT SUBMISSION // REV 2.0 (BIPT/CRA COMPLIANT)
Document Referentie: SES-CRA-TCF-2026-SE500-FINAL
Product: SE-500 Secure Industrial Gateway
Classificatie: Class I Critical Product (CRA Annex III, Categorie 1) [^1]
Conformiteitsroute: EU-typeonderzoek (Module B) + Conformiteit met het type (Module C) [^2]
Build Identifier: sha256:d4f1e5a88c22b902e4d3c1a5b8e9f0c2

SAMPLE REPORT BY LEONA

1. Administratieve Gegevens & Regelgevend Kader

1.1 Fabrikant en Productidentificatie

- **Fabrikant:** SecureEdge Systems B.V.
  - **Adres:** High Tech Campus 42, 5656 AE Eindhoven, Nederland
  - **Contactpersoon Compliance:** Ir. A. de Vries (compliance@secureedge.systems)
  - **Registratienummer:** KVK 12345678
- **Gedetailleerde Productidentificatie:**
  - **Modelnaam:** SE-500 Industrial Gateway
  - **Hardware Revisie:** v2.1.4 (PCBA Ref: SES-500-REVB)
  - **Firmware Versie:** v2.4.0-lts (Build Signature: `sha256:a4f1e5...`)
  - **Uniek ID (GTIN/EAN):** 8712345678901
- **Beoogd Gebruik & Doelgroep:** De SE-500 is ontworpen als een robuuste, beveiligde netwerkinterface voor de aggregatie van kritieke operationele data (OT) en het beheer op afstand (Remote Management) binnen industriële omgevingen (SCADA/ICS). Het apparaat is uitsluitend bestemd voor professioneel gebruik door gekwalificeerde systeemintegratoren en netwerkbeheerders in kritieke infrastructuren.
- **Ondersteuningsperiode & Lifecycle (Artikel 10, lid 6):** SecureEdge Systems verbindt zich formeel tot het leveren van beveiligingsupdates en kwetsbaarheidsafhandeling voor een minimale periode van **10 jaar** vanaf de datum van eerste ingebruikname op de markt.
  - **Startdatum marktintroductie:** 1 april 2026
  - **Gegarandeerde einddatum ondersteuning:** 31 maart 2036 [^3]

1.2 Certificeringspad & Juridische Context

Dit dossier is opgesteld om te voldoen aan de conformiteitsbeoordelingsvereisten van de **Cyber Resilience Act (CRA)**.

- **Regelgevende Status:** Gezien de classificatie onder **Annex III (Klasse I)** en het feit dat op het moment van indiening de relevante geharmoniseerde normen (zoals prEN 18031) nog niet definitief zijn gepubliceerd in het Publicatieblad van de EU (OJEU), volgt SecureEdge Systems de route van de **derde-partij toetsing**.
- **Aangemelde Instantie (Notified Body):** Het dossier is ingediend bij de geautoriseerde instantie voor een volledig EU-typeonderzoek volgens **Module B**. De productiecontrole vindt plaats via **Module C**.
- **BIPT Coördinatie:** Dit document is geformatteerd volgens de richtlijnen van het Belgisch Instituut voor Postdiensten en Telecommunicatie (BIPT) voor audit-gereedheid.

SAMPLE REPORT BY LEONA

2. Cybersecurity Risicobeoordeling (CRA Artikel 10)

Conform de eisen van de CRA is dit dossier gebaseerd op een systematische risicobeoordeling die gedurende de gehele productontwikkelingscyclus is uitgevoerd.

2.1 Methodologie & Scope

SecureEdge Systems hanteert de **STRIDE-methodiek** (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) voor dreigingsmodellering. De scope van deze analyse omvat:

1. **Hardware interfaces:** Fysieke toegang tot poorten (USB, Ethernet, UART).
2. **Firmware stack:** Bootloader, Kernel en User-space applicaties.
3. **Netwerkcommunicatie:** Cloud-telemetrie, lokale industriële protocollen (MQTT/Modbus).
4. **Data-at-rest:** Opslag van sleutels en configuratiedata op de eMMC.

2.2 Impact Scoring Criteria

De ernst van dreigingen wordt gekwalificeerd op basis van de potentiële impact op de **C.I.A. triad** (Confidentiality, Integrity, Availability):

- **Critical:** Volledige systeemovername, verlies van veiligheidsfuncties in OT-omgevingen.
- **High:** Grootschalige datadiefstal, manipulatie van kritieke procesdata.
- **Medium:** Lokale onderbreking van services, beperkte toegang tot niet-kritieke data.
- **Low:** Theoretische kwetsbaarheid zonder directe exploitatiemogelijkheid in de standaardconfiguratie.

SAMPLE REPORT BY LEONA

2.3 Gedetailleerde Matrix & Impact-analyse

ID	Dreiging (STRIDE)	Scenario	Impact	Waarschijnlijkheid	Mitigatie-strategie	CRA Annex I Ref	Restrisico
T1	Tampering	Injectie van malafide firmware via fysieke toegang tot de eMMC of boot-interfaces.	Critical	Medium	HAB v4 (Secure Boot) + dm-verity + Anti-rollback fuses.	1.1(e), 1.2(1)	Low
T2	Spoofing	Imitatie van de Cloud-backend om kwaadaardige commando's naar de gateway te sturen.	High	Low	Wederzijdse TLS 1.3 (mTLS) met hardware-fused certificaten.	1.1(c), 1.1(d)	Low
T3	Information Disclosure	Extractie van industriële geheimen of mTLS-sleutels via fysieke dump van de eMMC.	High	Low	LUKS2 (AES-XTS) encryptie; keys uitsluitend in OP-TEE enclave.	1.1(d)	Low
T4	Denial of Service	Resource-uitputting (CPU/RAM) door gefabriceerd MQTT-verkeer op de lokale poort.	Medium	High	cgroups v2 resource limiting + Nftables rate limiting.	1.1(g)	Medium
T5	Elevation of Privilege	Exploitatie van een kwetsbaarheid in de Edge-agent om root-toegang te verkrijgen.	Critical	Low	AppArmor sandboxing + Seccomp syscall filtering + PIE/NX hardening.	1.1(b), 1.1(h)	Low

SAMPLE REPORT BY LEONA

3. Deep-Dive Architectuur: Silicon to User-Space

3.1 Hardware Root of Trust (RoT) & Silicon Hardening

De beveiliging van de SE-500 is fundamenteel verankerd in het silicium van de **NXP i.MX8M Plus SoC**. Er is geen afhankelijkheid van software-only beveiliging tijdens de kritieke boot-fase.

- **High Assurance Boot (HAB v4):** De boot-sequentie start met een onwijzigbare Boot ROM (Primary RoT) die de cryptografische handtekening van de SPL (Secondary Program Loader) verifieert tegen de **Super Root Key (SRK)**hashes die permanent in de eFuses van de chip zijn gebrand. Elke bit-afwijking in de bootloader resulteert in een hardwarematige weigering van de executie.
- **CSU (Central Security Unit):** De CSU configureert de toegangspermissies voor alle hardware-periferie (zoals USB, Ethernet, DMA) op register-niveau. Tijdens de SPL-fase worden ongebruikte interfaces fysiek gedeactiveerd en de configuratie-registers 'locked', waardoor runtime-herconfiguratie door een aanvaller wordt uitgesloten.
- **TZASC (TrustZone Address Space Controller):** De LPDDR4-geheugenruimte is fysiek gepartitioneerd. De **TrustZone** technologie scheidt de Secure World (waarin OP-TEE en de key-management services draaien) van de Non-Secure World (Linux Kernel). De TZASC weigert elke geheugentoegang van de Linux Kernel tot de beveiligde regio's op hardware-niveau, zelfs bij een volledige 'Ring 0' compromis.
- **SNVS & Tamper Detection:** De Secure Non-Volatile Storage (SNVS) monitor bewaakt de omgevingsfactoren van de SoC. Bij detectie van fysieke sabotage via de externe **tamper pins** (bijv. openen van de behuizing) of extreme fluctuaties in spanning/temperatuur voert de hardware een onmiddellijke **Zeroization** uit van de Master Secret Keys in de CAAM secure-vault.
- **CAAM Job Rings:** De Cryptographic Accelerator (CAAM) is geconfigureerd met gescheiden Job Rings. Ring 0 is exclusief toegewezen aan OP-TEE voor cryptografische handelingen met 'Master Secrets', terwijl lagere Job Rings beschikbaar zijn voor de Linux kernel voor algemene versnelling van TLS-verkeer zonder toegang tot de hoofdsleutels.

3.2 Kernel & OS Hardening

Het secureEdge OS v2.4 (LTS) is geoptimaliseerd volgens de principes van het **Kernel Self Protection Project (KSPP)**.

- **dm-verity (Integrity Guard):** Het Root-bestandssysteem is een Read-Only SquashFS image. De `dm-verity`kernel-driver controleert elk gelezen block tegen een Merkle-tree waarvan de root-hash cryptografisch is ondertekend en ingebed in de FIT-image (Verified Boot).
    - **FEC (Forward Error Correction):** Gebruik van Reed-Solomon foutcorrectie om bit-rot op de industriële eMMC te herstellen zonder de integriteitscontrole te

SAMPLE REPORT BY LEONA

laten falen.

- **LSM (AppArmor) & Seccomp:** Elke actieve daemon (zoals de MQTT-client of de Cloud-agent) draait onder een strikt AppArmor-profiel.
    - **Path Restriction:** Toegang tot `/proc`, `/sys` en `/dev` is beperkt tot alleen noodzakelijke entries.
    - **Syscall Filtering:** Via Seccomp-BPF filters worden gevaarlijke systeemoproepen zoals `mount`, `reboot` of `ptrace` geblokkeerd voor applicatie-processen.
- **Memory Protections:** * `CONFIG_STRICT_KERNEL_RWX=y`: Voorkomt dat kernel-geheugenpagina's tegelijkertijd schrijfbaar en uitvoerbaar zijn (W^X).
    - `CONFIG_KASLR=y`: Address Space Layout Randomization voor zowel de kernel als de user-space binaries om ROP-attacks te bemoeilijken.
    - `CONFIG_STACKPROTECTOR_STRONG=y`: Geavanceerde stack canaries om buffer overflows in kritieke functies te detecteren.

SAMPLE REPORT BY LEONA

4. Essentiële Veiligheidseisen (CRA Annex I Mapping)

CRA Artikel	Requirement	Technische Bewijslast (Audit-ready)	Status
1.1(a)	Kwetsbaarheden	Dagelijkse triage via `meta-cve-check`. Machine-leesbare SBOM (CycloneDX) en VEX-data beschikbaar. Zie Sectie 5.3.	PASS
1.1(b)	Secure-by-Default	Debug-interfaces (JTAG/UART) hardwarematig vergrendeld via fuses. Alle onnodige services en poorten standaard gesloten.	PASS
1.1(c)	Toegangsbescherming	Geen universele default credentials. Root-toegang uitsluitend via unieke hardware-challenge (per-device). SSH via Public-Key only.	PASS
1.1(d)	Vertrouwelijkheid	AES-256-XTS encryptie (LUKS2) via hardware CAAM engine. Keys verlaten nooit de OP-TEE secure enclave.	PASS
1.1(e)	Systeemintegriteit	**dm-verity** implementatie met Forward Error Correction (FEC). Root-hash verankerd in ondertekende FIT-image (Verified Boot).	PASS
1.1(f)	Data Minimization	Lokale filtering en anonimisering van PII/metadata vóór verzending naar cloud-endpoints via de hardened Edge-agent.	PASS
1.1(g)	Beschikbaarheid (DoS)	Gebruik van Linux `cgroups v2` voor resource-quotas op netwerkprocessen. `Nftables` stateful inspection met rate-limiting.	PASS
1.1(h)	Attack Surface Reductie	Minimalistische RootFS (SquashFS). Verwijdering van alle onnodige Busybox applets en tools in de productie-image.	PASS
1.2(1)	Secure Updates	**RAUC** met hardware-fused anti-rollback index. Updates standaard ingesteld op 'Automatic' met ondertekende bundels (RSA-4096).	PASS
1.2(3)	Security Logging	Integratie van `Auditd` en remote logging via TLS. Alle configuratiewijzigingen triggeren een hardware-ondertekend event.	PASS

SAMPLE REPORT BY LEONA

5. Bewijs van Validatie & Hardening (Evidence Pack)

5.1 Binaire Hardening (Checksec Audit)

SecureEdge Systems past strikte toolchain-harding toe om geheugen-gebaseerde exploits (zoals buffer overflows en ROP-attacks) te mitigeren. Dit is een directe eis voor de robuustheid van kritieke netwerkinterfaces onder de CRA.

Uittreksel van `checksec` voor de hoofdbinaries (Firmware v2.4.0): | Binary | RELRO | STACK CANARY | NX | PIE | FORTIFY | | :--- | :--- | :--- | :--- | :--- | :--- | | `/usr/bin/se-gateway-daemon` | Full RELRO | Found | Enabled | Enabled | Yes | | `/usr/sbin/rauc` | Full RELRO | Found | Enabled | Enabled | Yes | | `/lib/libcrypto.so.3` | Full RELRO | Found | Enabled | Enabled | Yes |

- **Verificatie:** Alle binaries in `/usr/bin` worden gecompileerd met `-fstack-protector-strong`, `-D_FORTIFY_SOURCE=2`, en `-Wl,-z,now` (Full RELRO).
- **Bewijs:** Zie Bijlage CI-LOG-2026-03-19 voor de volledige compilatie-logs en de geautomatiseerde `checksec`rapportage van de CI/CD pipeline.

5.2 Cryptografische Isolatie & Key Management

Conform de eisen voor cryptografische integriteit (Annex I), maakt de SE-500 gebruik van een Trusted Execution Environment (TEE).

- **PKCS#11 Provider:** User-space applicaties (zoals de MQTT-client) communiceren met de CAAM via de **OP-TEE PKCS#11 provider**. Dit mechanisme zorgt ervoor dat private keys enkel binnen de Secure World worden geladen.
- **Architecturale Isolatie:** Architectuurdiagram SES-ARCH-002 (Bijlage) toont aan dat de communicatie verloopt via de **Secure Monitor Call (SMC)**. Zelfs bij een volledige overname van de Linux Kernel (Ring 0) blijven de keys fysiek onbereikbaar.
- **Hardware Fuses:** De SRK (Super Root Key) hashes zijn onherroepelijk in de eFuses gebrand, wat de integriteit van de boot-chain garandeert.

5.3 Machine-leesbare SBOM & VEX-rapportage

Conform Artikel 10 en Annex I, Sectie 2, levert SecureEdge Systems een machine-leesbare inventaris van alle softwarecomponenten.

- **SBOM Formaat:** Geleverd in **CycloneDX v1.5 JSON** formaat. Dit bestand bevat de volledige boomstructuur van 192 bibliotheken, inclusief versienummers, licenties en broncodes.

SAMPLE REPORT BY LEONA

- **VEX (Vulnerability Exploitability eXchange):** Voor de huidige build (`sha256:d4f1e5...`) zijn 12 upstream CVE's geïdentificeerd. Onze VEX-analyse (Bijlage SES-VEX-001) bewijst dat deze kwetsbaarheden **niet exploiteerbaar** zijn omdat de kwetsbare functies tijdens de compilatie zijn gestript of niet worden aangeroepen door de hardened kernel.

5.4 Reproductibiliteit van de Build

Om aan de eisen van het BIPT te voldoen wat betreft de integriteit van de supply chain, garandeert SecureEdge Systems **Reproducible Builds**.

- **Verificatie:** Gebruik van de Yocto Project bitbake-omgeving met hash-equivalence. Elke build resulteert in een bit-voor-bit identieke binary-output, wat onafhankelijke controle van de broncode-naar-binary transformatie mogelijk maakt.

SAMPLE REPORT BY LEONA

6. Incident Rapportage Protocol (Artikel 11)

SecureEdge Systems hanteert een strikt en geautomatiseerd protocol voor de rapportage van cyberincidenten en actief geëxploiteerde kwetsbaarheden, volledig in lijn met de dwingende termijnen van de Cyber Resilience Act.

6.1 Rapportage aan Autoriteiten (BIPT/ENISA)

Bij detectie van een incident dat de beveiliging van de SE-500 in gevaar brengt, worden de volgende stappen ondernomen via de officiële rapportagekanalen van het Belgische CSIRT en ENISA:

- **Vroegtijdige Waarschuwing (Binnen 24 uur):** Zodra een incident of een actieve exploitatie wordt vastgesteld (bijv. door een `dm-verity` integriteitsalarm of abnormaal verkeer gedetecteerd door de cloud-backend), wordt een initiële melding ingediend. Deze bevat de aard van het incident en eventuele onmiddellijke acties.
- **Incidentmelding (Binnen 72 uur):** Een gedetailleerd technisch rapport volgt, inclusief een analyse van de impact, de ernst (CVSS-score) en de status van de remediëring (bijv. de uitrolfase van de kritieke OTA-patch).
- **Eindverslag (Binnen 1 maand):** Na de afhandeling van het incident wordt een volledig retrospectief verslag ingediend met de definitieve bevindingen en maatregelen ter voorkoming van herhaling.

6.2 Gebruikersnotificatie & Transparantie

Conform Artikel 11, lid 4, worden getroffen professionele gebruikers onverwijld geïnformeerd:

- **Lokale Interface.** Een kritieke systeemwaarschuwing verschijnt in de lokale web-GUI van de gateway.
- **Cloud Dashboard:** Beheerders ontvangen een push-notificatie en e-mail via het SecureEdge Cloud Management Platform.
- **Remediëringsinstructies:** Indien handmatige interventie vereist is (bijv. herconfiguratie van firewall-regels na een exploit), worden stapsgewijze instructies en patches direct beschikbaar gesteld.

SAMPLE REPORT BY LEONA

7. Testrapportage & Validatie

Om de conformiteit te staven, is de SE-500 onderworpen aan een rigoureus testregime dat zowel statische als dynamische validatiemethoden omvat.

7.1 Statische Analyse (SAST)

Alle custom broncode van de Edge Agent en bijbehorende systeemscripts zijn geanalyseerd op programmeerfouten en beveiligingsrisico's.

- **Tools:** `cppcheck` voor C++ componenten en `Bandit` voor Python utilities.
- **Resultaat:** 0 openstaande "High Severity" waarschuwingen. Alle bevindingen met betrekking tot onveilige geheugenfuncties of onvoldoende inputvalidatie zijn verholpen in build v2.4.0.

7.2 Dynamische Analyse & Fuzzing (DAST)

De primaire aanvalsvectoren (netwerkstacks) zijn onderworpen aan intensieve robuustheidstesten om protocol-manipulatie te simuleren.

- **Methodologie:** Gebruik van `AFL++` (American Fuzzy Lop) voor geavanceerde instrumentatie van de parser-libraries.
- **Scope:** 500+ cumulatieve uren van fuzzing op de MQTT-stack (Mosquitto) en de TLS-handshake implementatie (OpenSSL).
- **Resultaat:** Geen crashes, buffer overflows of geheugenlekken (memory leaks) gedetecteerd die de beschikbaarheid of integriteit van de gateway in gevaar kunnen brengen.

7.3 Verificatie van Binaire Hardening

Post-build verificatie is uitgevoerd op alle binaries in het productiesysteem om te garanderen dat toolchain-hardening correct is toegepast.

- **Tool:** `checksec.sh`.
- **Scope:** 100% van de uitvoerbare bestanden in `/usr/bin/` en `/usr/sbin/`.
- **Resultaat:** Alle kritieke systeem-services tonen een status van 'Full RELRO', 'Stack Canary found' en 'NX/PIE enabled'.

7.4 Onafhankelijke Penetratietest

Een onafhankelijk cybersecurity-bureau (LCE) heeft een 'Grey Box' penetratietest uitgevoerd

SAMPLE REPORT BY LEONA

op de definitieve firmware-build.

- **Scope:** Network mapping, service discovery, authenticatie-bypass pogingen, en exploitatie van de cloud-interface.
- **Key Finding:** De fysieke hardwarematige isolatie via TrustZone bleek ondoordringbaar tijdens pogingen tot key-extractie vanuit de Linux user-space.
- **Verslag:** Het rapport (Ref: LCE-PENTEST-2026) is bijgevoegd als formeel bewijs van functionele security-validatie.

7.5 Continue Kwetsbaarheidsscan

Onze CI/CD-pipeline integreert dagelijkse scans tegen de NVD (National Vulnerability Database).

- **Methodiek:** Gebruik van de `meta-cve-check` Yocto layer.
- **Status:** Alle geïdentificeerde kwetsbaarheden voor de huidige build-signature zijn geëvalueerd en, indien van toepassing, verholpen of gemitigeerd via VEX-verklaringen.

SAMPLE REPORT BY LEONA

Juridische Verwijzingen & Voetnoten

1: **Annex III, Categorie 1:** Gateways en netwerkinterfaces worden geclassificeerd als Klasse I Kritieke Producten.
2: **CRA Artikel 24:** Voor Klasse I producten is de betrokkenheid van een Notified Body verplicht voor de conformiteitsbeoordeling (Module B+C).
3: **Verordening (EU) 2024/2847 (Cyber Resilience Act):** Officiële wettekst van het Europees Parlement en de Raad.

SAMPLE REPORT BY LEONA